Synnovis Incident Analysis and Recommendations

Provided to: Department of Health and Social Care

ID: 37078169

1 Purpose

The aim of the paper is to analyse the Synnovis ransomware attack that occurred the 3rd of June 2024 to understand legal implications, regulatory aspects and organizational perspectives, assuming that security failings are found to exist after the ICO investigation. Furthermore, since this analysis is made in order to give recommendations on how to proceed, directed to a Senior Executive Officer of the Department of Health and Social Care (DHSC), the core issues to be addressed and identified are the breaches of regulations, common law or health/safety duties. It will help the executives make decisions since the study will provide a comprehensive analysis of the pathology service current situation. Finally, this paper will provide an estimation of the potential ICO fine that Synnovis might face, based on comparative precedent cases. This study is essential for improving NHS protection as a critical infrastructure, guiding board level vendor management.

2 Introduction

On the 3rd of June 2024, Synnovis was victim of a major ransomware cyberattack. Synnovis is a pathology partnership (joint-venture) between Guy's St Thomas's NHS Foundation Trust (GSTT), King's College Hospitals NHS Trust (KCH), and SYNLAB, the largest provider of medical testing and diagnostics in Europe. It provides critical pathology and medical diagnostics services to NHS major hospitals and GP practices across London. The attack was deemed to be "calculated" and had UK's critical healthcare infrastructure in the scope. Most of Synnovis's systems were paralysed during the attack by the ransomware, including analysers, laboratory information management systems, and result transmission platforms.

3 Background

All the relevant information has been collected from official sources (e.g. Synnovis's website, ICO's website)[1]

3rd of June 2024, ATTACK. Synnovis systems are compromised by the ransomware: machines are compromised and 400GB of data gets scraped. The authors of this attack are members of the Russian hacker group "Qilin". Immediate investigation begins, involving IT taskforce from Synnovis, Trust Partners, NHSE and third party specialists. Synnovis got also in touch with the National Crime Agency (NCA), the National Cyber Security Centre (NCSC) and the Information Commissioner's Office (ICO). They reported to be in contact with the ICO and law enforcement agencies since the attack.

4th of June 2024, NHS CRISIS DECLARED. NHS England declares that there has been a "critical incident". More than 11,000 outpatient and elective appointments cancelled and more than 1,700 elective operations postponed (mainly affecting the South-East London boroughs). Blood transfusion services are disrupted and caused O-negative blood shortage at national level. Hospitals are forced to revert to manual processes.

20th of June 2024, DATA PUBLICATION. They discover that the data has been scraped in haste and in a random manner from their working drives, no data was taken from their primary lab databases. The data attackers scraped is fragmented and Laboratory Information Management Systems (LIMS) were not posted, meaning the main patient test request/results databases were not directly exposed. Following, the criminal group, after not receiving the £ 50 million ransom requested, published the sensitive data on the Dark Web. The group communicates with BBC journalists through qTox (an encrypted channel) and declares that the attack was "calculated" and was a punishment for unspecified geopolitical reasons[2].

July 2024, LEGAL INJUNCTION. Synnovis manages to obtain an urgent legal injunction to protect patients, colleagues and service users by preventing subsequent publication of the data, even though it provides limited practical protection once the data is available online. Meanwhile, they started working with a team of cyber security specialists to identify any organisations and individuals the stolen data may relate to (this operation will take more than one year).

June-Autumn 2024, RECOVERY OPERATIONS. In this time span the pathology provider works on its IT infrastructure, managing to rebuild more than 60 interconnected systems, and begins the forensic investigation in order to reconstruct which organizations' data was affected. Core pathology functions are finally restored as well (Hospitals and GPs are provided with their services again).

Late Autumn 2024, FULL RESTORATION. Synnovis's services are fully restored to its pre-attack capacity. Forensic investigation still ongoing.

Late 2025, BREACH NOTIFICATION ISSUED. After 18 months of analysis and completing the forensic investigation, on the 10th of November 2025 Synnovis notifies affected organizations. Laterally affected organizations begin notifying controllers and this process is expected to be concluded the 21st of November 2025. The analysis conducted by a data breach specialist, CaseMatrix, estimates more than 900,000 NHS patients' data compromised, although it is not confirmed by Synnovis.

3.1 Additional Information

MORE CONTEXTUAL INFORMATION. On the 18th of April, about a month before the Synnovis attack, Synlab Italia (Synlab's Italian subsidiary) was hit by a ransomware deployed by "Black Basta": a different threat actor than "Qilin" but still linked to Russia. This indicates that Synlab was a target even before the attack

[1] ICO, https://ico.org.uk/media2/migrated/4030744/ic-322233-d9n6-response.pdf - Synnovis https://www.synnovis.co.uk/cyberattack-information-centre

[2] https://www.bbc.co.uk/news/articles/ceddqglk7qgo

to UK's critical infrastructure. It also raises questions about the eventual correlation between the two attacks, in terms of shared infrastructure vulnerabilities between the English and the Italian labs.

PATIENT DEATH. In June 2025, King's College Hospital NHS Trust confirms that the cyber attack, as a collateral damage, "contributed to" at least one patient death. Patient's blood test results had been delayed by the attack during recovery: direct causal link was established. This is one of the few documented instances of a patient fatality linked directly to a ransomware. This detail is crucial, since it is a significant aggravating factor for the legal analysis and regulatory assessment.

4 Initial legal analysis and critical facts

ATTACK VECTORS AND ROOT CAUSE. The real chain of events is undisclosed from public sources (the ICO's investigation is still ongoing)[3], so the initial access of the threat actor and the attack vectors can only be assumed at the moment, based on ransomware trends: (i) Unprotected remote access protocol without MFA; (ii) Exploitation of known unpatched vulnerabilities; (iii) Social engineering to obtain credentials; (iv) Supply chain attack via third-party vendor.

4.1 Regulatory Context

The ICO is the main regulator in these cases, since there has been a breach of the UK GDPR 2018. ICO regulates the lifecycle of data and enforces the law when data is not handled as it should be by controllers or processors (e.g. data compromising, malpractice, ect.). In this case, the core problem is the patients' sensitive data leakage caused, presumably, by the lack of security controls in place by the Synnovis (processor). ICO recommends always the "cyber basics": MFA, patch management, recurrent vulnerability assessments. Moreover, ICO treats ransomware as a high priority risk, and it is a serious breach of UK GDPR's Art 32.

5 Controllers vs Processor: Legal Roles

First of all a clear definition of the roles that organizations play in the data lifecycle (generation, storage, transit, processing) is crucial to understand the legal implications posed by statutes (e.g. UK GDPR 2018) and case law.

A **data controller**, by definition of the Art 4(7) UK GDPR 2018, is the natural or legal person, public authority, agency, or other body that determines the purposes and means of processing personal data. It decides "why" and "how" of a data processing activity. Legally, it stands on the highest level of expected UK GDPR compliance for data protection principles, listed in Art 5 of the UK GDPR 2018.

A **data processor**, on the other hand, defined by the Art 4(8) UK GDPR 2018, is a separate actor in the data lifecycle: it processes data strictly on behalf of, and under documented and precise instructions of, the data controller. Nevertheless, even if they serve the controller's interests rather than their own, they still hold independent obligations under the UK GDPR 2018. If they want to involve sub-processors they need the controller's authorization first. A processor mandatorily has to implement technical and organizational security principles (Art 32), assist the controller in responding to breaches or data subject requests. Crucially, if a processor is targeted by a cyber attack and it causes personal data compromise due to a security failure, it now can be held directly liable and fined by the ICO.

In this specific context, controllers are the individual NHS trusts (GSTT, KCH), GP practices and public/private clinics, while the processor is Synnovis. SYNLAB, the European parent company, provides services to Synnovis and can potentially be a sub-processor for Synnovis (not confirmed from public sources). In that case it would be subject to the same security measures.

During the pre-attack situation the controllers determined the tests to order, what data to collect, how to store it according to standards and crucially they had the responsibility for complying to the statutory obligations. Synnovis was the actor responsible for the sample and data processing on behalf of the controllers. It had to implement security measures imposed by the Art 32 UK GDPR 2018. Controllers must enter into a binding contract or other legal act with their processors, which must contain a number of compulsory provisions as specified in Art 28(3) UK GDPR 2018.

6 Statute and Comparative Precedent Analysis

6.1 Statute Breach Analysis

Disclaimer: Until this point of the paper, it has been hypothesized that several laws, from different statutes/acts, have been broken by the NHS Trusts' pathology service provider. In this section these potential breaches will be analysed in detail, with correlated evidence for each breach. All the following statements are assumption based on evidence and case precedents. ICO's Lawyers might interpret how the law applies to the facts differently (e.g. Literal Rule, Mischief Rule, Golden Rule)

- **UK General Data Protection Regulation** (UK GDPR) 2018, the primary legislation that controls how personal information is used by organizations.
  - The primary breach falls under **Article 32(1) UK GDPR 2018**. Synnovis has failed to implement technical and organizational measures (TOMs) to ensure an appropriate level of security. It can be assumed that the security features in place were not proportional to the risk of processing data in such a high impact role. Specifically, Synnovis failed under **Art 32(1)(b) UK GDPR 2018** that involves the ability to ensure the "ongoing confidentiality, integrity, availability, of processing systems". Synnovis serves multiple major NHS Trusts, it is an essential service, it is expected to have the best security posture. Shockingly, as they have declared on their website, the company achieved the Cyber Essential Plus certification only recently[4], several months after the attack, simultaneous with the end of the forensic investigation in late 2025. This enforces the hypothesis that Synnovis did not have the correct security measures in place to prevent, or at least minimize, the outcome of the ransomware attack of June 2024. In this case, Synnovis also fails under

[3] ibid

[4] https://www.synnovis.co.uk/news-and-press/ceplus-accreditation

the **Art 32(1)(d) UK GDPR 2018**, which mandates a process for "regularly testing, assessing and evaluating the effectiveness" of those measures. Furthermore, the scale of the exfiltrated data (400 GB of data collected in a "random manner") suggests that baseline protections, such as MFA, were either absent or severely inadequate[5].

- Possible breach of the **Article 33(1) UK GDPR 2018**: while Synnovis states that they got in touch promptly with the ICO, there is not yet any public source available that can support this. A failure or delay to notify ICO within 72 hours could result as an aggravating factor.
- **Article 34** is also assumed to be broken by Synnovis, since they had a 18-months lag in notifying data subjects (patients) of the data breach[6]. The Art mandates that when a breach is "likely to result in a high risk to the rights and freedoms of natural persons," requiring notification "without undue delay." Especially in this case the breach involves patients' sensitive data, that is special category data under the Art 9.
- **Article 28**, rules the controller-processor legal relation. Under Art 28(3)(c) UK GDPR 2018, if Synnovis failed to maintain adequate TOMs, the company not only breached the Art 32, but they are also violating statutory obligations as processors to their controllers (NHS Trusts). It mandates a binding data processing agreement and pursue damages from the processor to recover liabilities incurred under Art 82 of the UK GDPR 2018.
- **Article 82**: this article of the regulation established that 'any person who has suffered material or non-material damage as a result of an infringement of this Regulation shall have the right to receive compensation." The consequences of the attack (delays/cancellation of appointments, tests, surgeries etc.) creates a huge liability surface for civil lawsuits seeking damages for distress (non-material) and clinical harm (material).

- **Data Protection Act (DPA) 2018** is "an Act to make provision for the regulation of the processing of information relating to individuals; to make provision in connection with the Information Commissioner's functions under certain regulations relating to information; to make provision for a direct marketing code of practice; and for connected purposes".[7]
  - **Section 155**, this section grants the ICO the power to issue fines against organizations that fail under UK GDPR 2018. Under the Art 83(4)(a) UK GDPR 2018, processors that don't respect the regulatory contract between controller and processor established under the Art 28 and don't have enough security measures illustrated by the Art 32, they can be fined can reach up to **£ 8,70 million or 2% of the global annual turnover from the preceding year**. Therefore, if Synnovis is found liable for not complying to the statutory guidelines this is the maximum monetary penalty it could be facing. On the other hand, NHS Trusts as data controllers, face the same tier of penalty if they fail to vet or mandate security measures for their processor under the Art 28 of the UK GDPR 2018. The punishment could be traced back to the parent company SYNLAB: if the ICO pushes the 2% monetary penalty to them the maximum fine could be huge.
  - **Section 198** provides the tools to the ICO to prosecute individual executives in case the offence (malpractice under the UK GDPR 2018) has been proven to have been committed by a body corporate. The ongoing forensic investigation on Synnovis will reveal whether there is any offence from the board members that can fall under this.
- **Health and Safety at Work etc. Act 1974**
  - **Section 3(1), read along section 37,** dictates that employers are obliged to conduct their "undertaking in such a way as to ensure, so far as is reasonably practicable, that persons not in his employment... are not thereby exposed to risks to their health or safety." The English legal system could be seeing a novelty if the family of the patient that died, due to the collateral effects of the ransomware attack on Synnovis in July 2025, decided to take actions against the company and the controllers. Section 37 allows the prosecution of executives if the breach that caused the fatality can be proven to be caused through their "consent, connivance or neglect." It would be the first time that this section is applied to a cyber-physical incident, alongside data protection laws.
    This could happen after a careful review of board papers from NHS Trusts.
    A brief analysis of some of the board minutes conducted specifically for this paper (from meetings before and after the Synnovis attack of June 2024), revealed that cybersecurity, or more broadly cyber resilience, was not a priority (e.g. July 2022 heatwave that disrupted the GSTT IT systems) and several times risks regarding IT failures had been downgraded or entirely removed from the corporate risk register.
    KCH board paper from 2023 show that they knew third-party cyber risk was material and had at least some structured engagement with Synnovis pre-incident.
    A more in-depth analysis of this papers could reveal important details about corporate decision and, therefore, shift the eventual court decision.
    Hypothetically, if there is evidence, executives that deliberately ignored statutory health and safety duties or failed in their duty to save money or time could face several criminal charges, including manslaughter as a consequence via gross negligence or s.37 of HSWA 1974 considering the KCH patient's fatality that is directly linked with the ransomware attack.
- **Computer Misuse Act (CMA) 1990**

[5] https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/security/a-guide-to-data-security/
[6] ibid
[7] https://www.legislation.gov.uk/ukpga/2018/12/introduction/enacted

Even if **Qilin** (Threat Actor usually prosecuted civilly via injunctions as Persons Unknown, e.g. *XXX v Persons Unknown [2022] EWHC 2776 (KB)* case[8]) bears criminal culpability for the cyber attack that would fall under Computer Misuse Act 1990, s.1(1) for unauthorized access and s.3(1) for impairing computer operations with a ransomware, it is on the judges discretion to decide whether the hacker group will be held accountable for the KCH patient's death under the s.3ZA(1) read with s.3ZA(3)(a) and (f) of the CMA 1990 , or if the fatality was ultimately caused by corporate executives' negligence under HSWA.

6.2 Precedent Analysis: The *Advanced* Case

In March 2025 ICO released a penalty notice against Advanced Computer Software Group Ltd [9]. It is the closest related scenario to the Synnovis situation and legal commentaries suggest that it is the benchmark for the future ICO decision. Advanced, after an infringement of the Art 32(1) UK GDPR 2018, caused by a ransomware attack in 2022 has been fined for £ 3.07 million (NHS 111 service disruption).

Key statutory distinctions and direct parallels will shape the Synnovis case:

- **Art 32 UK GDPR 2018 infringement**: the *Advanced* punishment shows how the ICO explicitly penalised the company under Art 32(1)(b) UK GDPR 2018 for lacking MFA on publicly exposed environments and for not conducting regular vulnerability assessments. Finding the implementation of those a challenge for the company is not considered an excuse. Since the Advanced case happened 2 years before Synnovis's, and it widely put the healthcare supply chain on notice, the ICO will find the company's neglect of basic TOMs as significantly aggravating.
- **Distinction in the role severity**: *Advanced* breach caused administrative issues, but, as the ICO reports, there is a lack of confirmed physical harm. On the other hand, the attack on Synnovis infrastructures halted crucial pathology services and caused a shortage in blood supply across seven major hospitals in London. Based on the ICO fines guidance published in 2024 it will place Synnovis on a higher starting band compared to Advanced.
- **Who will be fined**: In the *Advanced* case, the ICO pushed the penalty back to the parent company (Aston Midco Ltd). Applying this same legal mechanism to Synnovis, the monetary penalty could be redirected to the corporate parent Euro SYNLAB Group. If the liability ends on SYNLAB the fine will dramatically increase, from the flat £ 8.7 million statutory cap to well over that amount, considering its multi-billion global annual turnover.

7 Final Considerations and Recommendations for DHSC

At this point, it is possible to start drawing conclusions on the eventual outcome of this attack from a legal point of view for Synnovis and its controllers, ending with recommendations for the DHSC about the next steps to take regarding this situation. The ICO investigation is still going on, therefore there is not yet official information about what are the actual legal implications of the company after the attack.

However, from the evidence collected, it can be assumed that:

- Synnovis, just as the Advanced Computer Software Group Ltd, will be considered *guilty* of breaking several laws under the UK GDPR 2018 by the ICO. The way the attack and data exfiltration happened suggests severe security flaws in their IT systems. Moreover, several other aggravating factors compound the company's regulatory/civil liability, for instance the fact that it operates as a critical infrastructure and that the data breach exposed highly sensitive patient information. Most severely, the resulting operational disruption directly contributed to a patient's fatality, alongside delays/cancellations of important appointments and surgeries ending with the halting of the national blood transfusion services. Furthermore, the attack was considered a cascade risk, as SYNLAB's Italian branch had been attacked just a month prior in 2024. Also, as mentioned in the previous sections, the fact that Synnovis obtained a Cyber Essentials Plus (CE+) certification only after the attack strongly underlines the pre-incident lack of cyber resilience measures. This processor-level negligence could legally implicate the NHS Trusts. Under Art. 28 of the UK GDPR, data controllers bear a strict statutory obligation to proactively vet and verify the efficacy of their vendors' Technical and Organisational Measures (TOMs). Consequently, the Trusts' failure to enforce these baseline security standards prior to the breach exposes them to shared regulatory liability.
- Conversely, there are also mitigating factors that may reduce potential penalties: the leaked data was not from the primary LIMS database, the initial compromise was unexpected with no evidence that suggests sustained prior access. The company did not pay the ransom, keeping their ethical stance and they report to be gotten in touch immediately with NCA,NCSC and ICO, showing a quick response to the incident for operational recovery. Moreover, Synnovis also conducted a rigorous 18-months long data investigation, obtained an urgent legal injunction and kept a full cooperation with law enforcement.

7.1 ICO fine prediction

Based on the trend from the ICO for cases similar to this, a quick calculation of an approximated fine can be made (Tuckers[10], Advanced[11]):

[8] https://www.twobirds.com/en/disputes-plus/shared/insights/2022/uk/practical-assistance-from-the-courts-in-relation-to-ransomware-attacks-xxx-v-persons-unknown-2022

[9] https://ico.org.uk/media2/gdlfddgc/advanced-penalty-notice-20250327.pdf

[10] Information Commissioner's Office, 'Monetary Penalty Notice: Tuckers Solicitors LLP' https://webarchive.nationalarchives.gov.uk/ukgwa/20221003152939mp_/https://ico.org.uk/media/action-weve-taken/mpns/4019746/tuckers-mpn-20220228.pdf

[11] ibid

Table 1: ICO fine estimation

FACTORS	Tuckers	Advanced	Synnovis
Sector criticality	Low	High	**Critical**
Data sensitivity	Medium	High	**High**
Scale affected	Medium	Medium	**Large**
Service disruption	Low	High	**Critical**
Patient death	N/A	No	**Yes**
Recovery time	Weeks	300 days	**180 days ca.**
Fine (£)	98k	3.07m	**4-8m**

The estimated monetary penalty ranges between £ 4-8 millions because there are still uncertainties that will be resolved by the ICO forensic investigation.

7.2 Recommendations

(1) **[Preferred] R1**: Given the multiple occasions in which the NHS infrastructure (including supply chains) has been found unprepared for cyberattacks, it is advised to establish a **cyber security mandate for critical infrastructures**. The DHSC must issue binding guidance that will require every organization that works for or inside the healthcare's infrastructure, that is classified as a tier 1 critical processor, to comply to rigorous security standards (e.g. ISO27001 certifications) and regular penetration testing by NCSC approved firms. This might sound costly, but it has a huge ROI, not only financially because compliance protects organisations from regulatory fines and scrutiny, but also in terms of reliability, trust and more broadly national health.

(2) **R2**: **Critical service redundancy policy**. Critical national infrastructure must embrace the security by design principle, and therefore, be able to deploy adequate security measures as disaster recovery plans. The Synnovis case is a stark warning: the disruption of a single pathology service provider caused huge damage, reaching nation-level criticality in a short time (e.g. blood supply shortage). There is a pressing need for structural resilience. Services must be distributed across multiple, network-segmented providers, in order to be isolated. Whenever one provider is halted there is at least one or more service provider ready to assume operational capacity until the affected systems are restored.

(3) **R3**: It is advised to invoke **material breach and execute a managed exit strategy**. Given the negligence demonstrated by Synnovis (specifically, from the lack of cybersecurity measures, compounded by the fact that they obtained the Cyber Essential Plus (CE+) certification only after clinical harm occurred), DHSC should advise GSTT and KCH to declare formally the breach of the Data Processing Agreement. Nevertheless, if the termination of the collaboration has immediate effect, it would result in a clinical disruption even more catastrophic than the cyberattack itself. Therefore, a multi-step exit process spread over two to three years must be initiated. This time frame allows the healthcare providers and the DHSC to understand whether it is safer to find a new vendor (with standardised and verified industry-level TOMs) or to stop the outsourcing of critical services. Investing in an "in-house" pathology laboratory would restore strict governance over critical infrastructure under NHS full operational control.

A Personal learning points

During the review of the Synnovis attack episode, I learnt:

- How to approach cyber incidents by a legal point of view, understanding all the legal implications and the collateral outcomes;
- How to search for relevant legal literature and statues, specifically for the English Legal System;
- That standards and laws are not made just be enforced, instead they are crafted to protect and safeguard people's rights.

B Generative AI Usage Disclosure

Perplexity (Pro Version) by Perplexity AI, Inc. (https://www.perplexity.ai) was used for tone and readability feedback, grammar and spelling checks, and organize the collected relevant data.

References

R v Ashley [2013] EWCA Crim (Court of Appeal upheld two-year custodial sentence under the Computer Misuse Act 1990).

Computer Misuse Act 1990, Section 3ZA: unauthorised acts causing, or creating risk of, serious damage.

Crown Prosecution Service, "Computer Misuse Act" ⟨https://www.cps.gov.uk/prosecution-guidance/computer-misuse-act#_Toc532920187⟩ accessed 24 February 2026.

Guy's and St Thomas' NHS Foundation Trust, "Our Board — Agenda and Papers" ⟨https://www.guysandstthomas.nhs.uk/about-us/our-board/agenda-and-papers⟩ accessed 24 February 2026.

Health and Safety at Work etc Act 1974.

Information Commissioner's Office, *Freedom of Information Response: IC-322233-D9N6* (, Information Commissioner's Office 2024) ⟨https://ico.org.uk/media2/migrated/4030744/ic-322233-d9n6-response.pdf⟩ accessed 24 February 2026.

— *Statement in Response to Synnovis Cyber Attack* (, Information Commissioner's Office 2024) ⟨https://ico.org.uk/about-the-ico/media-centre/news-and-blogs/2024/06/statement-in-response-to-synnovis-cyber-attack/⟩ accessed 24 February 2026.

— "A Guide to Controllers and Processors" ⟨https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/controllers-and-processors/controllers-and-processors-a-guide/⟩ accessed 24 February 2026.

King's College Hospital NHS Foundation Trust, "Board Papers" ⟨https://www.kch.nhs.uk/about/how-we-are-organised/board-of-directors/minutes-and-agendas/⟩ accessed 24 February 2026.

XXX v Persons Unknown [2022] EWHC 2776 (KB) (Cavanagh J; permanent injunction granted arising from ransomware attack).

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (United Kingdom General Data Protection Regulation) 2016.

Synnovis Group LLP, "Synnovis Group LLP Cyber Update" ⟨https://synnoviscyberupdate.co.uk/⟩ accessed 24 February 2026.

The Data Protection, Privacy and Electronic Communications (Amendments etc) (EU Exit) Regulations 2019, SI 2019/419.